

Real-World Exploits & Web Pentesting

1.Introduction

This report explores advanced topics in web application security, including real-world hacking techniques, Burp Suite usage, and Capture The Flag (CTF) challenges. The goal is to gain hands-on experience in web pentesting.

2. Real-World Hackers & Security Loopholes

Real-world hackers discover vulnerabilities by:

- Scanning websites using automated tools.
- Looking for outdated libraries, insecure configurations, or unvalidated inputs.
- Using tools like Burp Suite, Nmap, and Nikto to probe for weaknesses.
- Exploiting common web vulnerabilities like SQL Injection, XSS, SSRF, and CSRF.
- Participating in Bug Bounty programs and responsibly disclosing vulnerabilities.

3. Advanced Web Application Penetration Testing

Advanced pentesting involves:

- Mapping the web application structure.
- Bypassing authentication mechanisms.
- Manipulating parameters, headers, and cookies.
- Exploiting vulnerabilities manually and using tools like Burp Suite's Intruder, Repeater, and Decoder modules.
- Reporting the impact, risk level, and mitigation strategies.

4. Introduction to CTF (Capture The Flag)

CTFs are gamified cybersecurity challenges where participants:

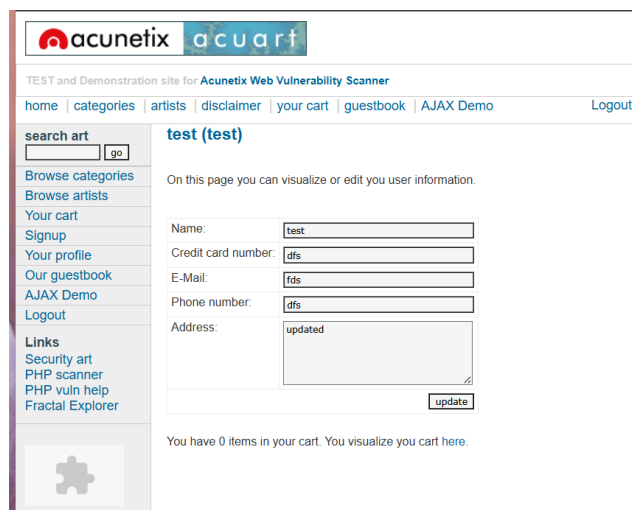
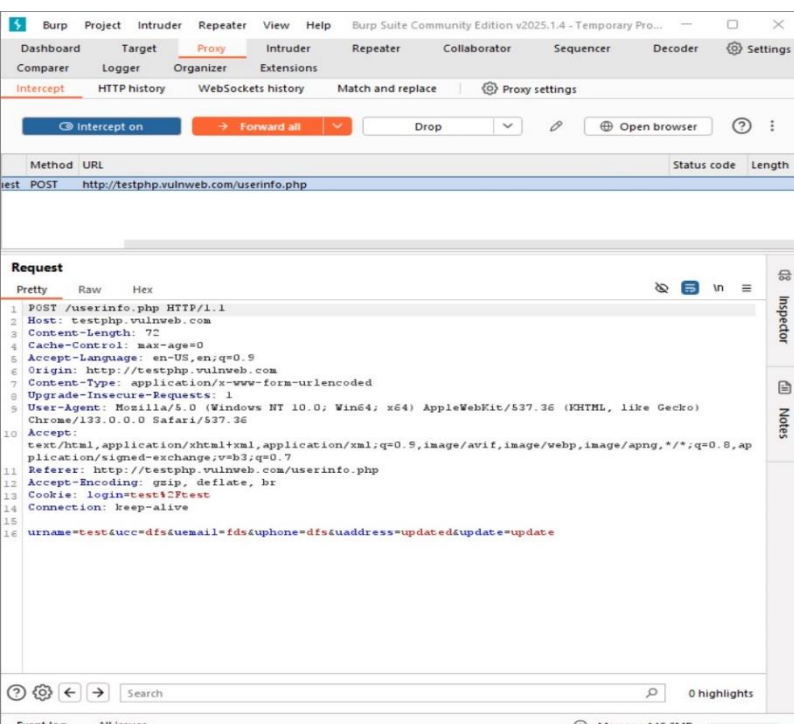
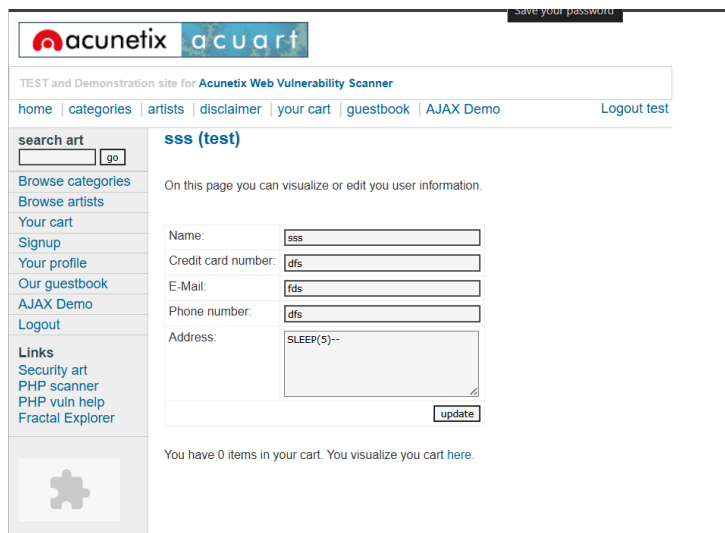
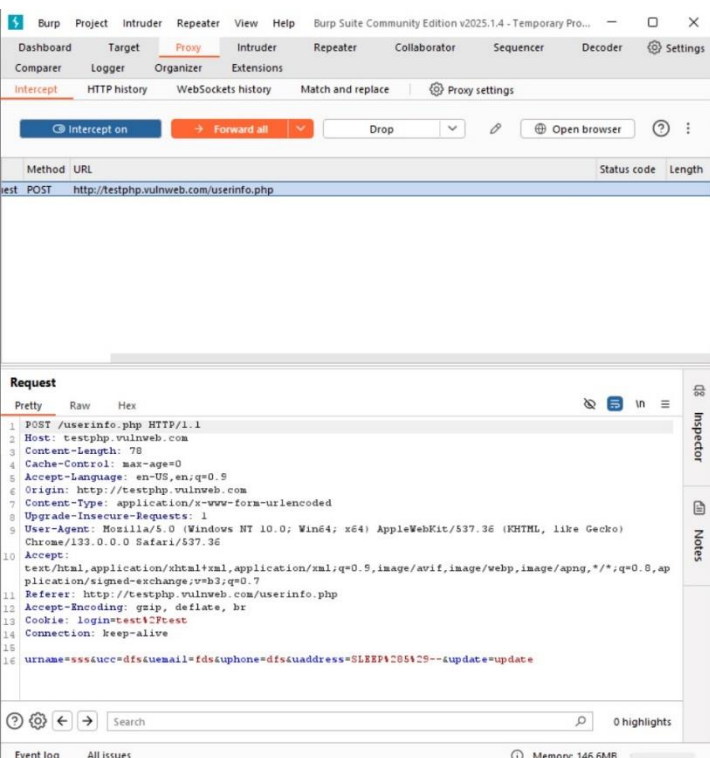
- Solve real-world-like security problems.
- Gain flags (e.g., THM{flag_here}) as proof of completion.
- Learn ethical hacking, reverse engineering, cryptography, and web exploitation.

TryHackMe and Hack The Box are popular platforms with beginner-to-expert level labs.

5. Hands-On with Burp Suite

Used Burp Suite to:

- Intercept HTTP requests/responses.
- Modify form parameters and headers.
- Analyze vulnerabilities like XSS and SQLi.
- Reconstruct login bypass scenarios using Intruder and Repeater.



Task B

Platform: Local (OWASP Juice Shop)

objective: Explore and exploit common web vulnerabilities using Burp Suite.

- Accessed the **OWASP Juice Shop** interface to begin testing.
- Used **Burp Suite** to **intercept and modify HTTP requests** from the browser.
- Observed and modified parameters in real-time to test for potential vulnerabilities.
- Practiced identifying input fields vulnerable to attacks like **XSS** and **SQL Injection** (no flag captured but analysis was done).

